

Corporate Cybersecurity Framework

Task 2: Cybersecurity Policy | Task 3: Risk Assessment Matrix

Task 2: Cybersecurity Policy

This policy establishes the minimum security standards for all company information systems, devices, and personnel. Compliance is mandatory to safeguard organization data and infrastructure against evolving cyber threats.

1. Password Complexity Requirements

To prevent brute-force attacks and unauthorized access, all user accounts must adhere to strict complexity standards:

- **Minimum Length:** Passwords must be at least 14 characters long.
- **Character Variety:** Must include at least three of the following four categories: Uppercase letters (A-Z), Lowercase letters (a-z), Numbers (0-9), and Special characters (e.g., !, @, #, \$, %, ^, *).
- **Expiration & Reuse:** Passwords do not expire automatically unless a breach is suspected (aligned with modern NIST guidelines), but the system will block the reuse of the last 5 history passwords.
- **Prohibited Items:** Passwords cannot contain the user's account name, real name, or easily guessable dictionary words (e.g., 'Password123').

2. Multi-Factor Authentication (MFA)

MFA adds a critical layer of defense beyond standard credentials.

- **Mandatory Enforcement:** MFA is required for all employees accessing corporate systems, including email, VPNs, cloud applications (e.g., Microsoft 365, AWS), and HR portals.
- **Approved Factors:** Authentication must utilize an approved authenticator app (e.g., Microsoft Authenticator, Google Authenticator) via push notifications or Time-based One-Time Passwords (TOTP).
- **Disallowed Methods:** SMS and voice-call authentication are strictly prohibited due to SIM-swapping vulnerabilities, unless explicitly approved by the IT Security team as a temporary fallback.

3. Device Encryption

Data-at-rest must be protected against physical theft or loss of hardware.

- Full Disk Encryption (FDE): All corporate-issued endpoints (laptops, desktops, smartphones) must have full disk encryption enabled.
 - Windows Devices: Must utilize BitLocker with a minimum of AES-256 bit encryption.
 - macOS Devices: Must utilize FileVault 2.
- Key Management: Encryption recovery keys must be securely escrowed and managed centrally by the IT department; users are prohibited from modifying encryption settings.

4. Antivirus & Endpoint Detection and Response (EDR) Standards

Continuous monitoring and malware prevention must be maintained on all endpoints.

- Deployment: Every endpoint must run the centralized corporate EDR/Antivirus solution (e.g., Microsoft Defender for Endpoint).
- Configuration: Real-time scanning and behavioral analysis must remain active at all times. Definition updates must occur automatically at least once every 24 hours.
- Tamper Protection: Users are strictly barred from disabling, pausing, or uninstalling security software. Any alert generated will automatically log to the central Security Operations Center (SOC).

5. Patch Management

Software vulnerabilities must be mitigated swiftly to prevent exploitation.

- Automated Updates: Operating systems and third-party applications (browsers, productivity suites) must be enrolled in automated patch management cycles.
- Deployment Timelines: Patches will be deployed based on severity rankings:
 - Critical/Zero-Day Vulnerabilities: Patched within 48 hours of release.
 - High Severity: Patched within 14 days of release.
 - Medium/Low Severity: Patched within the standard monthly maintenance window (30 days).
- Reboot Policy: If a patch requires a system restart, users will receive a maximum 72-hour deferral window before a forced reboot occurs.

6. Acceptable Use Policy (AUP)

Employees must utilize corporate technology resources responsibly, ethically, and legally.

- Business Resource Only: Company systems, networks, and devices are provided primarily for business purposes. Incidental personal use is permitted if it does not interfere with productivity or compromise security.
- Prohibited Activities: Employees shall not use corporate assets to access, download, or distribute pornographic, hate speech, or illegal material; engage in gambling, torrenting, or unauthorized file-sharing; or install unapproved third-party software or shadow IT applications.
- Reporting Obligation: Employees must immediately report any suspected security incidents, lost devices, or phishing attempts to the IT Helpdesk.

Task 3: Risk Assessment Matrix

The following matrix identifies core operational risks, assesses their likelihood and impact, and outlines specific mitigation controls, informed by standards from Microsoft Learn, CompTIA Security+, and Google IT Support Frameworks.

Risk	Likelihood	Impact	Mitigation Controls
Phishing	High	High	Ongoing security awareness training; annual phishing simulations; robust email filtering gateways (DMARC/DKIM/SPF enforcement).
Ransomware	Medium	High	Implementation of localized EDR; strict network segmentation; automated, immutable, and offsite (3-2-1 rule) backup strategies.
Hardware Failure	Medium	Medium	Server and storage redundancy (RAID configurations); maintaining on-site spare hardware; documented hardware lifecycle replacement plans.
Power Outage	Medium	High	Uninterruptible Power Supplies (UPS) for localized servers/networking gear; automated backup generators for critical data centers; migration of core infrastructure to the cloud.
Data Leakage (Insider Threat)	Medium	High	Implementation of Data Loss Prevention (DLP) software; strict role-based access control (RBAC); principle of least privilege enforcement.
Unpatched Vulnerabilities	High	Medium	Routine vulnerability scanning; strict adherence to the patch management policy timelines; automated asset management discovery.

References & Framework Resources

- Microsoft Learn – Enterprise Security Architectures and Blueprint Foundations

- CompTIA Security+ – Domain 1.0 (Threats, Attacks, and Vulnerabilities) & Domain 5.0 (Governance, Risk, and Compliance)
- Google IT Support Professional Certificate – Bits and Bytes of Networking & IT Security: Defense against the digital dark arts